DEVSECOPS LAB BOOK · PHASE 12: COMPLIANCE & GOVERNANCE

Chapter 32

Compliance Implementation

SOC2 Type II • PCI-DSS • HIPAA • GDPR • ISO 27001

Mapping security controls to requirements, automating evidence collection, and preparing for audit — an instructor's walkthrough of this chapter.

SESSION OVERVIEW

What We'll Cover

32.1 Control Mapping Matrix

One control, many frameworks — how a single implementation satisfies five regimes at once.

32.2 SOC2 Type II

Trust service categories and automated evidence collection.

32.3 PCI-DSS

The 12 requirements and how the platform addresses each.

32.4 HIPAA Security Rule

Administrative, physical, and technical safeguards for ePHI.

32.5 GDPR

Core principles and data-subject rights implementation.

32.6 ISO 27001

Annex A control categories, A.5 through A.18.

32.7 Automated Evidence

The monthly compliance report pipeline, end to end.

32.8 Audit Readiness

The pre-audit checklist that ties it all together.

32.1 — CONTROL MAPPING

One Control, Five Frameworks

Each implemented control is cross-referenced against every applicable requirement — so evidence is captured once and reused everywhere.

Access Control

Authentik (OIDC) SOC2 CC7.1 · PCI 8.1 · HIPAA 164.312(a)(2)(i) · GDPR 32
Teleport (MFA) SOC2 CC7.2 · PCI 8.3 · HIPAA 164.312(a)(2)(i)
RBAC Policies SOC2 CC7.2 · PCI 8.2 · HIPAA 164.308(a)(4)
Vault Secrets SOC2 CC6.1 · PCI 8.2.3 · HIPAA 164.312(a)(2)(ii)
Audit Logging SOC2 CC7.4 · PCI 10.1 · HIPAA 164.312(b)

Encryption

TLS / mTLS SOC2 CC6.1 · PCI 4.1 · HIPAA 164.312(e)(2) · GDPR 32
Vault PKI SOC2 A1.1 · PCI 4.1 · HIPAA 164.312(a)(2)(ii)
Database Encryption PCI 3.4 · HIPAA 164.312(a)(2)(ii) · GDPR 32
Backup Encryption SOC2 CC6.1 · PCI 3.4 · HIPAA 164.312(a)(2)(ii)

Vulnerability Mgmt

SonarQube (SAST) PCI 6.5.1 · ISO27001 A.14.2.1
Harbor Scanning PCI 6.2 · ISO27001 A.12.6.1
DefectDojo PCI 6.5 · HIPAA 164.308(a)(1)(ii)(B)
Patching PCI 6.2 · ISO27001 A.12.6.1

Monitoring & Logging

ELK Stack SOC2 CC7.3 · PCI 10.1 · HIPAA 164.312(b)
Prometheus SOC2 CC7.2 · ISO27001 A.12.4.1
Wazuh SIEM SOC2 CC7.2 · PCI 11.4 · HIPAA 164.308(a)(5)(ii)
Audit Trail SOC2 CC7.4 · PCI 10 · GDPR 32

Trust Service Categories in Practice



CC7.1

User Access Restriction

Cluster role bindings, role bindings, and sudoers reviewed as evidence.



CC7.2

System Monitoring

auditd status, active audit rules, and live Prometheus metric counts.



CC7.3

Organizational Policies

Security policy files and system resource limits captured monthly.



CC7.4

Audit Logging

30-day audit search counts and audit log storage volume tracked.



C1

Availability

Kubernetes node status and cluster health snapshots.



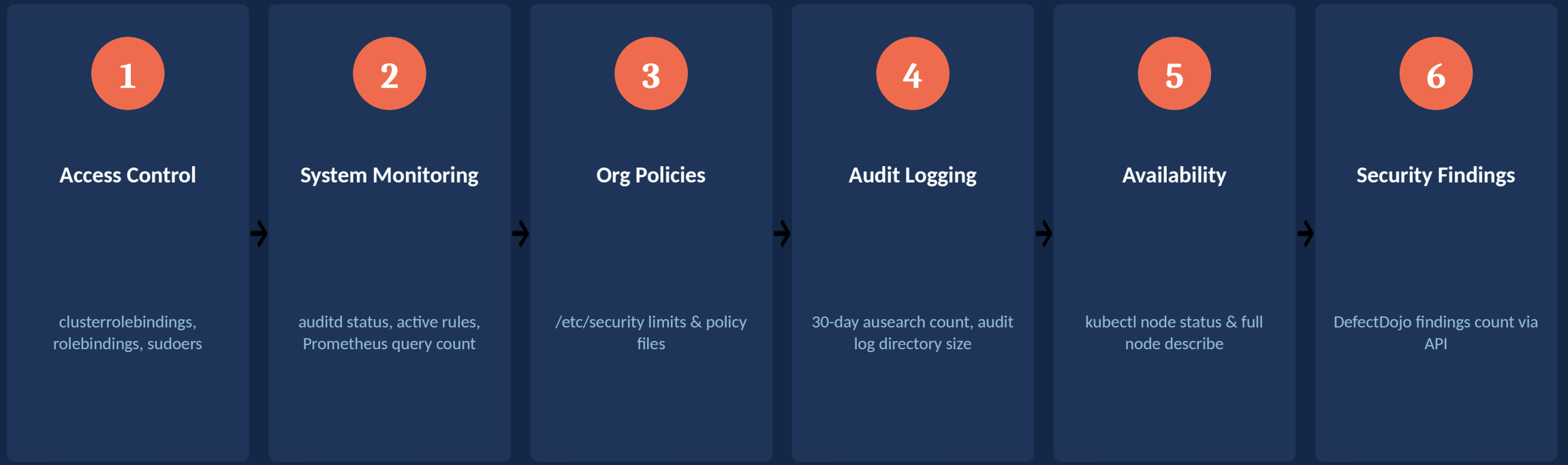
S1

Security

Open-finding counts pulled directly from DefectDojo's API.

soc2-evidence-collection.sh

A single monthly script sweeps five evidence domains into a dated, audit-ready archive.



Output: all evidence is tar.gz-packaged monthly as soc2-evidence-YYYY-MM-DD.tar.gz for direct handoff to auditors.

The 12 Requirements at a Glance

R1 Firewall Configuration

R2 No Default Credentials

R3 Cardholder Data Protection

R4 Strong Encryption

R6 Secure Development

R8 User Access Control

R10 Logging & Monitoring

R11 Testing & Monitoring

Requirements 5, 7, 9, and 12 (malware protection, need-to-know restriction, physical access, and security policy) apply org-wide and are tracked in the parent governance program.

Requirements 8 & 10 — Access and Logging

Requirement 8 — User Access

- ✓ Unique user IDs for every individual — no shared logins
- ✓ MFA enforced on all administrative and remote access
- ✓ Strong password policy: 12+ characters with complexity
- ✓ Formal access provisioning / deprovisioning process
- ✓ Periodic (at minimum quarterly) access reviews

Requirement 10 — Logging

- ✓ All access to cardholder data environments logged
- ✓ Audit logs are immutable and tamper-evident
- ✓ Centralized log retention across the platform
- ✓ Logs protected from unauthorized modification
- ✓ Regular, scheduled log monitoring and review

Administrative, Physical, Technical Safeguards



Administrative

- Security management process (annual risk analysis, documented risk management)
- Assigned security responsibility
- Workforce security
- Annual security awareness training
- Security incident procedures



Physical

- Facility access controls
- Workstation security
- Device & media controls



Technical

- Access controls: unique user ID, emergency access, encryption/decryption
- Audit controls
- Integrity controls
- Transmission security — encryption for ePHI in transit

Six Core Principles of Processing

Lawfulness, Fairness & Transparency

Legal basis, documented privacy policy, consent, and processing agreements.

Purpose Limitation

Data collected for a specified purpose; no secondary use without consent.

Data Minimization

Collect only what's needed; enforce a clear retention policy.

Accuracy

Keep personal data accurate; allow subject-initiated corrections.

Storage Limitation

Maximum 3-year retention with automated, scheduled purging.

Integrity & Confidentiality

TLS + at-rest encryption, RBAC, pseudonymization, annual testing.

Data Subject Rights, Implemented

Right to Access

Self-service portal

Right to Correction

In-app update mechanism

Right to Deletion

Automated deletion workflow

Right to Portability

One-click JSON / CSV export

Right to Restrict

Processing pause flag

Right to Object

Opt-out mechanism

Annex A Control Categories

- A.5 Organizational Controls
- A.6 People Controls
- A.7 Asset Management
- A.8 Access Control
- A.9 Cryptography
- A.10 Physical Controls
- A.11 Operations
- A.12 Communications Security
- A.13 System Acquisition
- A.14 System Maintenance
- A.15 Supplier Relations
- A.16 Incident Management
- A.17 Continuity
- A.18 Compliance

The Monthly Compliance Report Pipeline

#	Evidence Domain	Source	Output Artifact
1	**Security Controls**	kubectl, Vault, Terraform	k8s-resources.json, vault-secrets.json
2	**Vulnerability Status**	DefectDojo API, Trivy	vulnerabilities.json, container-scan.json
3	**Access Control Audit**	kubectl RBAC, auth.log	rbac-audit.txt, access-audit.txt
4	**Network & Firewall**	UFW, route, netstat	firewall-rules.txt, listening-ports.txt
5	**Backup & Recovery**	Backup dir, restore test	backup-status.txt, recovery-test.txt
6	**Incident & Audit Logs**	audit.log, journalctl	audit-trail.txt, kubelet-logs.txt
7	**Patch Status**	apt, dpkg	patches-available.txt, installed-packages.txt
8	**Compliance Status**	OpenSCAP, Lynis	cis-compliance.txt, security-audit.txt

Final step: a COMPLIANCE-SUMMARY.txt is generated with pass/fail counts, then the full report directory is tar.gz-packaged for auditor handoff.

Before-Audit Readiness Checklist

- All controls mapped to requirements
- Evidence collection automated
- Policies documented
- Procedures followed
- Vulnerabilities remediated
- Access reviews completed
- Audit logs centralized
- Backup restore tested
- Incident response tested
- Team trained

WRAP-UP

From Evidence to Audit-Ready

Next steps from the automated report:

- Review findings
- Update controls as needed
- Remediate vulnerabilities
- Document changes
- Notify stakeholders

Compliance Officer Sign-Off

Every monthly report closes with a named compliance officer and date — accountability baked into the artifact, not bolted on after.

Discussion: which control in your own stack could satisfy two frameworks at once?